



SISTEMA DE BIBLIOTECA

Projeto Integrador — Entrega Parcial 5

Autenticação, Sessões e Controle de Acesso por Perfil

Aluno: Hezron Daniel M C Canturil | Leandro Caitano | Luilson Vieira

Polo: Sobradinho — BA | Equipe: 03

github.com/luilsonvmartins/Projeto-e-Implementa-o-de-Sistemas-para-Web-2

PHP 8+

bcrypt

Sessões

Perfis

MVC

MySQL

Identificação	
Alunos	Hezron Daniel M C Canturil Leandro Caitano dos Santos Luilson Vieira Martins
Polo	Sobradinho — BA
Disciplina	Projeto e Implementação de Sistemas para Web II
Entrega	Entrega Parcial 5 — Semana 12 (30 pts) — Autenticação e Controle de Acesso
Repositório	github.com/luilsonvmartins/Projeto-e-Implementa-o-de-Sistemas-para-Web-2

1. Objetivo da Entrega

A Entrega Parcial 5 implementa o sistema completo de **segurança e autenticação**, substituindo o login simulado das etapas anteriores por autenticação real com **bcrypt**, controle de **sessão segura**, **perfis de usuário** (admin e leitor) e **proteção de rotas** por perfil.

2. Funcionalidades Implementadas

Funcionalidade	Descrição
Login real com bcrypt	password_verify() compara a senha digitada com o hash armazenado no banco
Logout seguro	Destrói sessão, limpa cookie e redireciona para login
session_regenerate_id()	Previne session fixation attack ao autenticar
Controle de sessão	Dados do usuário (id, nome, perfil) armazenados na sessão após login
Perfis: admin e leitor	Enum no banco; funções isAdmin() e requirePerfil() no helpers.php
Proteção de rotas	requireLogin() em todas as páginas; requirePerfil('admin') nas áreas restritas
Gerenciamento de usuários	CRUD completo de usuários — exclusivo para administradores
Página Meu Perfil	Qualquer usuário pode ver seus dados e alterar a própria senha
Alteração de senha	Verifica senha atual antes de permitir troca; valida confirmação
Badge de perfil na navbar	Exibe 'admin' em destaque para administradores
Dica de login na tela	Exibe credenciais padrão para facilitar avaliação
Dois usuários de teste no banco	admin@biblioteca.com / admin123 e leitor@biblioteca.com / leitor123

3. Autenticação com bcrypt

O PHP fornece nativamente as funções `password_hash()` e `password_verify()` para hash seguro de senhas com o algoritmo bcrypt. Nunca armazenamos a senha em texto puro — apenas o hash gerado.

app/controllers/AuthController.php — autenticar()

```
public function autenticar(?string $p = null): void {
    $email = trim($_POST['email'] ?? '');
    $senha = $_POST['senha'] ?? '';

    $usuarioModel = new Usuario();
    $usuario = $usuarioModel->porEmail($email); // busca só usuários ativos

    // Verifica existência E senha com bcrypt
    if (!$usuario || !password_verify($senha, $usuario['senha'])) {
        setFlash('erro', 'E-mail ou senha incorretos. ');
        redirect('auth/login');
    }

    // Previne session fixation
    session_regenerate_id(true);

    // Armazena na sessão
    $_SESSION['usuario_id'] = $usuario['id'];
    $_SESSION['usuario_nome'] = $usuario['nome'];
    $_SESSION['usuario_perfil'] = $usuario['perfil'];

    setFlash('sucesso', 'Bem-vindo, ' . $usuario['nome'] . '!');
    redirect('home/index');
}
```

app/models/Usuario.php — hash ao cadastrar

```
public function inserir(array $d): bool {
    // Gera hash bcrypt da senha antes de salvar
    $hash = password_hash($d['senha'], PASSWORD_BCRYPT);
    $stmt = $this->db->prepare(
        "INSERT INTO usuarios (nome,email,senha,perfil) VALUES (:nome,:email,:senha,:perfil)"
    );
    return $stmt->execute([
        ':nome' => trim($d['nome']),
        ':email' => trim($d['email']),
        ':senha' => $hash, // nunca a senha em texto puro
        ':perfil' => $d['perfil'] ?? 'leitor',
    ]);
}
```

4. Controle de Sessão e Perfis de Usuário

Três funções em `helpers.php` controlam o acesso em todo o sistema:

app/helpers.php — funções de controle de acesso

```

// Verifica se há um usuário logado
function isLoggedIn(): bool {
    return isset($_SESSION['usuario_id']);
}

// Redireciona para login se não autenticado
function requireLogin(): void {
    if (!isLoggedIn()) {
        setFlash('erro', 'Faça login para continuar.');
```

```

        redirect('auth/login');
    }
}

// Exige perfil específico (ex: 'admin')
function requirePerfil(string $perfil): void {
    requireLogin();
    if ($_SESSION['usuario_perfil'] ?? '' !== $perfil) {
        setFlash('erro', 'Acesso negado.');
```

```

        redirect('home/index');
    }
}

// Retorna true se o usuário é administrador
function isAdmin(): bool {
    return ($_SESSION['usuario_perfil'] ?? '') === 'admin';
}

```

5. Proteção de Rotas por Perfil

Cada controller verifica o nível de acesso no início de cada método. Rotas públicas (login) não exigem autenticação. Rotas gerais exigem **requireLogin()**. Rotas de gestão de usuários exigem **requirePerfil('admin')**.

Rota	Proteção	Acesso
/auth/login	Pública	Qualquer visitante
/home/index	requireLogin()	Qualquer usuário logado
/livro/*	requireLogin()	Qualquer usuário logado
/autor/*	requireLogin()	Qualquer usuário logado
/categoria/*	requireLogin()	Qualquer usuário logado
/usuario/index	requirePerfil('admin')	Somente admin
/usuario/criar	requirePerfil('admin')	Somente admin
/usuario/editar	requirePerfil('admin')	Somente admin
/usuario/deletar	requirePerfil('admin')	Somente admin
/usuario/perfil	requireLogin()	Qualquer usuário logado
/usuario/alterarSenha	requireLogin()	Qualquer usuário logado

6. Logout Seguro

O logout destrói completamente a sessão, incluindo o cookie, impedindo que dados do usuário permaneçam no navegador.

app/controllers/AuthController.php — logout()

```
public function logout(?string $p = null): void {
    // Limpa array de sessão
    $_SESSION = [];
    // Remove o cookie de sessão
    if (ini_get('session.use_cookies')) {
        $params = session_get_cookie_params();
        setcookie(session_name(), '', time() - 42000,
            $params['path'], $params['domain'],
            $params['secure'], $params['httponly']
        );
    }
    session_destroy();
    redirect('auth/login');
}
```

7. Como Executar no XAMPP

1	Extraia sistema-biblioteca-EP5.zip em C:\xampp\htdocs\sistema-biblioteca
2	Inicie Apache e MySQL no painel do XAMPP
3	phpMyAdmin → aba SQL → cole o conteúdo de banco.sql → Executar
4	Acesse: http://localhost/sistema-biblioteca/public
5	Login admin: admin@biblioteca.com / admin123
6	Login leitor: leitor@biblioteca.com / leitor123
7	Teste: o leitor não vê o menu Usuários — só o admin tem acesso

8. Próxima Entrega — Projeto Final

Com as 5 entregas parciais concluídas, o sistema está pronto para a etapa final: deploy em produção, documentação completa e vídeo demonstrativo.

Item	Descrição
Deploy	Publicar a aplicação em servidor online (ex: InfinityFree, Railway, ou VPS)
Repositório GitHub	Manter código atualizado com commits organizados por entrega
Documentação completa	README detalhado, manual do usuário, diagrama ER e descrição técnica
Vídeo demonstrativo	Gravação mostrando todas as funcionalidades do sistema em funcionamento

